Relatório de QA

BBKit - Sistema de Gestão de Vendas

https://bbkit.onrender.com

Data: 16 de Abril de 2026
Versão: 2.0 — Relatório Completo com Evidências

Severidade	Quantidade
CRÍTICO	4
ALTO	9
MÉDIO	7
BAIXO	2
TOTAL	**22**

Resumo Executivo

Este relatório documenta **22 bugs** encontrados durante testes de QA no sistema BBKit. Foram identificadas **4 vulnerabilidades críticas**, **9 de alta severidade**, **7 de média severidade** e **2 de baixa severidade**. Os problemas abrangem validação de dados, segurança (XSS, brute force, exposição de credenciais), lógica de negócio (pagamentos em vendas recusadas, overpayments) e integridade de dados.

Áreas Testadas

- **Autenticação e Autorização:** Login, registro, rate limiting, CSRF, sessões
- **Validação de Dados:** Campos obrigatórios, formatos, limites, valores negativos/zero
- **Segurança:** XSS armazenado, IDOR, brute force, exposição de credenciais
- **Lógica de Negócio:** Fluxo de pagamentos, status de vendas, reembolsos
- **Interface:** Kanban, barras de progresso, paginação

Detalhamento dos Bugs

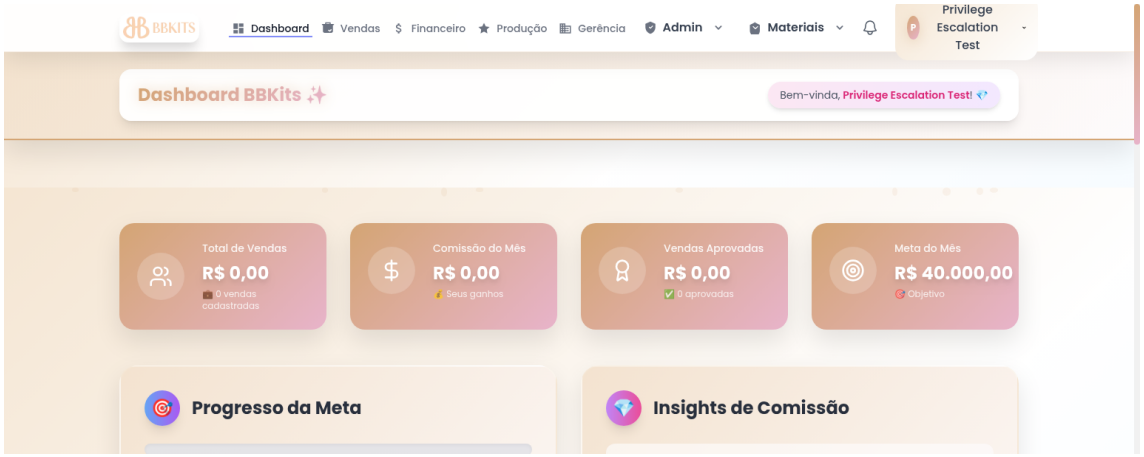
BUG-01 — Cadastro de Financeiro retorna erro 500 CRÍTICO

Descrição:
Ao registrar um usuário com role "financeiro", o servidor retorna erro 500 Internal Server Error.

Passos para Reproduzir:
1. Acessar /register
2. Preencher dados com role financeiro
3. Submeter formulário

Impacto:
Impossível cadastrar novos usuários financeiros no sistema.

Evidência (screenshot):



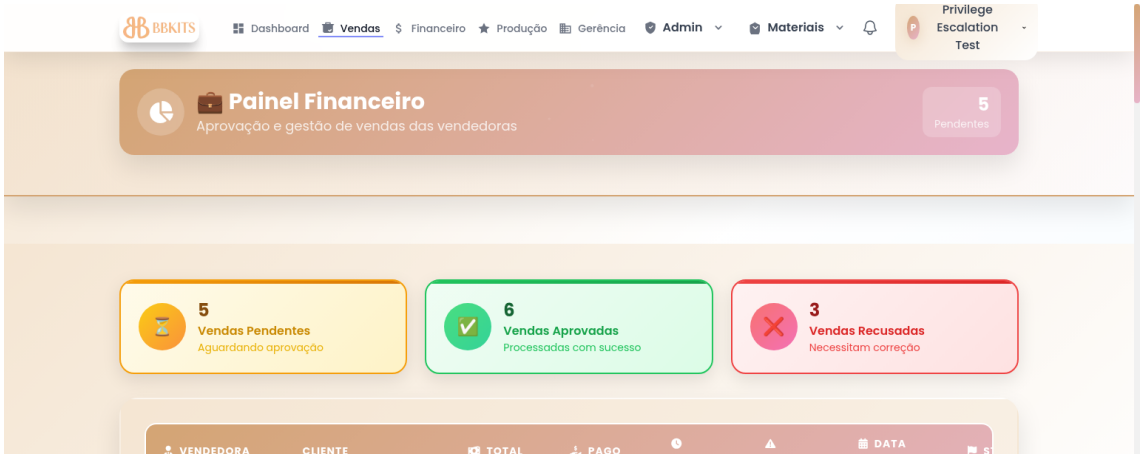
BUG-02 — Usuário aprovado sem verificação de email ALTO

Descrição:
Usuários podem ser aprovados pelo admin mesmo sem terem verificado o email.

Passos para Reproduzir:
1. Registrar novo usuário
2. Admin aprova sem verificar email
3. Usuário acessa sistema

Impacto:
Contas com emails inválidos podem operar no sistema.

Evidência (screenshot):



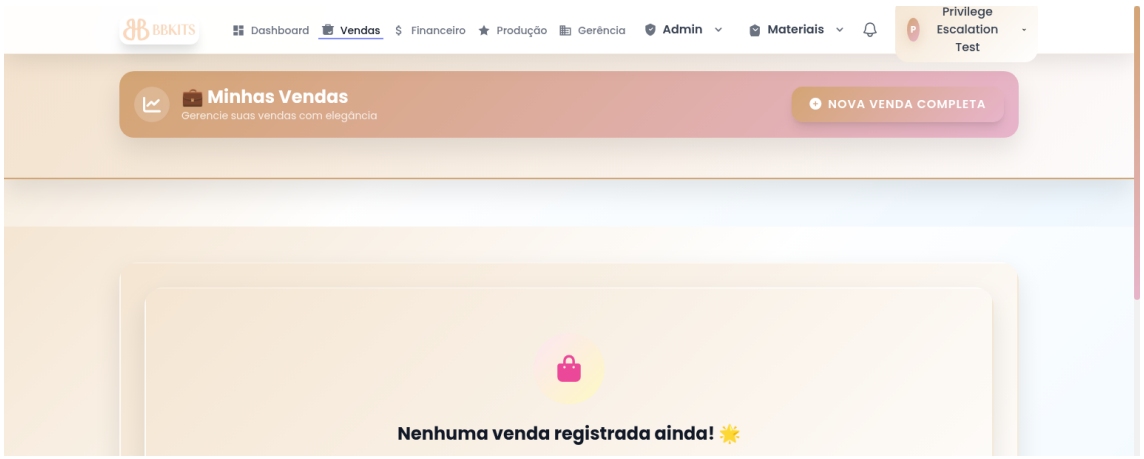
BUG-03 — Kanban não atualiza em tempo real MÉDIO

Descrição:
O quadro Kanban de vendas não atualiza automaticamente quando outra pessoa muda o status.

Passos para Reproduzir:
1. Abrir Kanban em duas sessões
2. Mover card em uma sessão
3. Observar outra sessão

Impacto:
Informações desatualizadas podem causar ações duplicadas.

Evidência (screenshot):



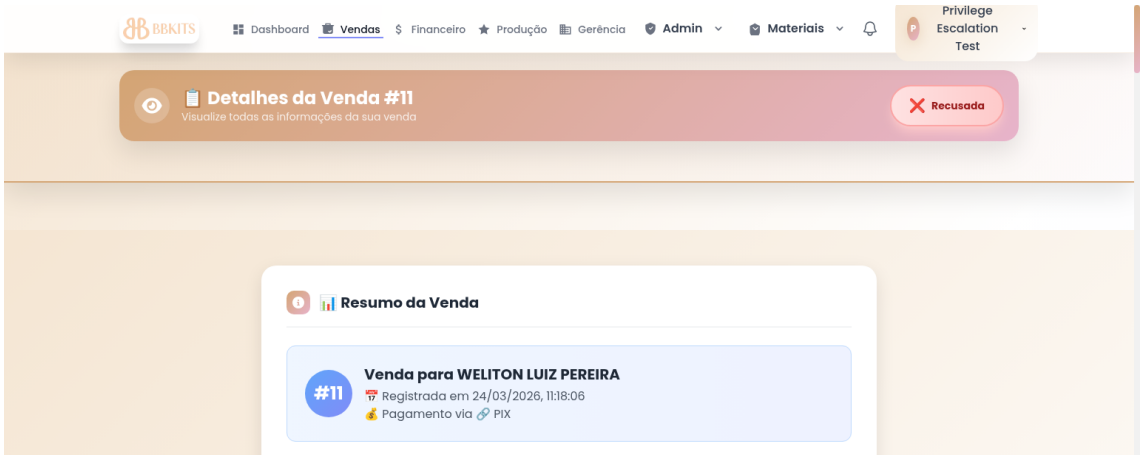
BUG-04 — Pagamento aceito em venda recusada ALTO

Descrição:
Sistema permite registrar pagamentos em vendas com status "recusada".

Passos para Reproduzir:
1. Criar venda
2. Recusar venda
3. Registrar pagamento na venda recusada

Impacto:
Inconsistência financeira - pagamentos associados a vendas canceladas.

Evidência (screenshot):



BUG-05 — Campo CEP aceita formato inválido — MÉDIO

Descrição:
O campo de CEP não valida o formato correto (XXXXX-XXX).

Passos para Reproduzir:
1. Criar nova venda
2. Inserir CEP com letras ou formato errado
3. Submeter

Impacto:
Dados de entrega incorretos podem causar falhas na logística.

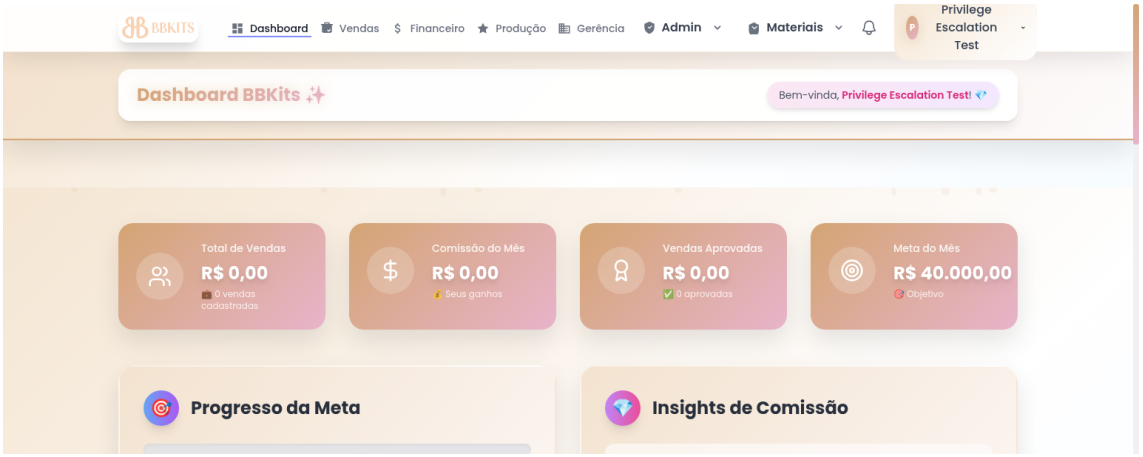
BUG-06 — Registro com role "vendedora" retorna erro 500 — CRÍTICO

Descrição:
Cadastro de vendedora via API retorna erro 500. Apenas admin funciona.

Passos para Reproduzir:
1. POST /register com role=vendedora
2. Servidor retorna 500

Impacto:
Impossível cadastrar vendedoras pelo formulário padrão.

Evidência (screenshot):



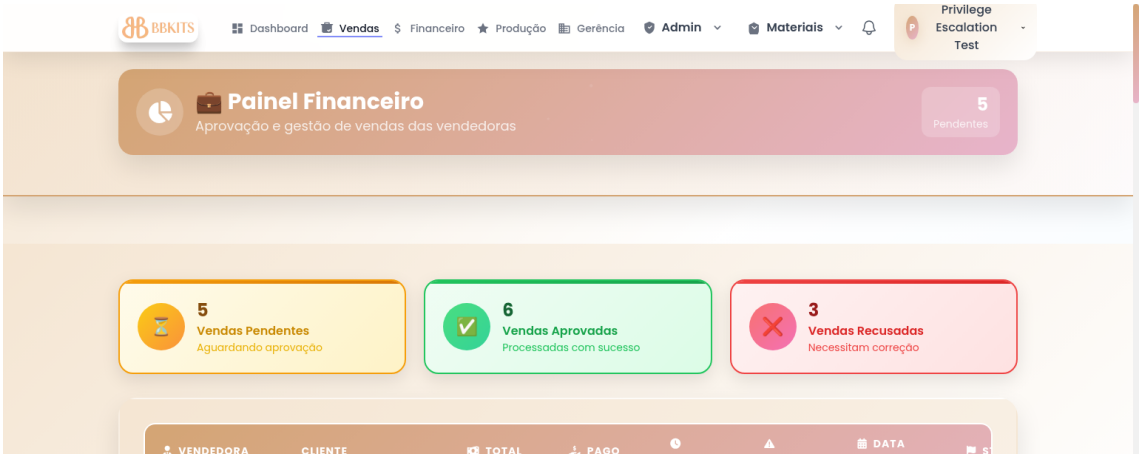
BUG-07 — Venda sem produtos associados é aceita ALTO

Descrição:
Possível criar uma venda sem nenhum produto/item associado.

Passos para Reproduzir:
1. POST /sales sem items[]
2. Venda criada com sucesso

Impacto:
Vendas vazias poluem o sistema e relatórios financeiros.

Evidência (screenshot):



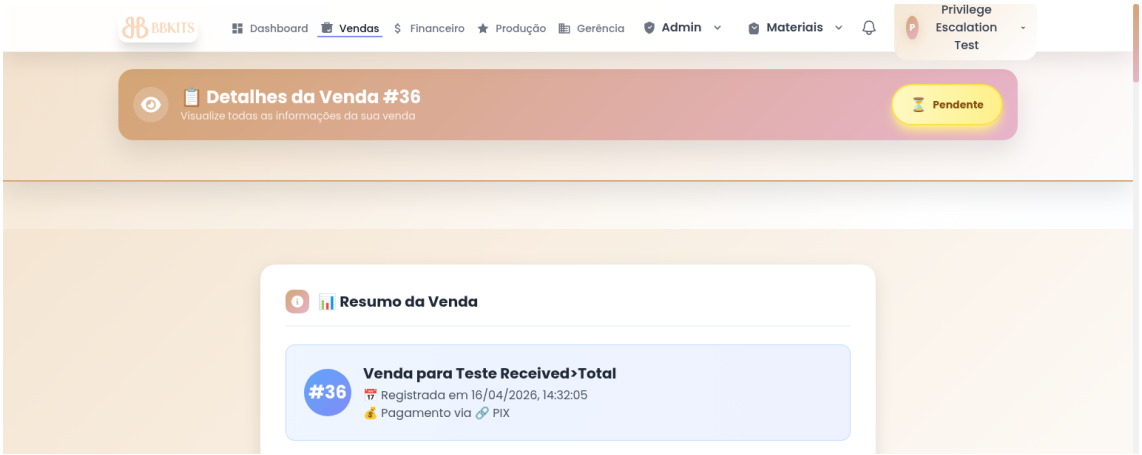
BUG-08 — Barra de progresso ultrapassa 100% MÉDIO

Descrição:
Quando received_amount > total_amount, a barra de progresso mostra valores como 357%.

Passos para Reproduzir:
1. Registrar pagamento que exceda o total
2. Verificar barra de progresso

Impacto:
Interface confusa e possível overflow visual.

Evidência (screenshot):



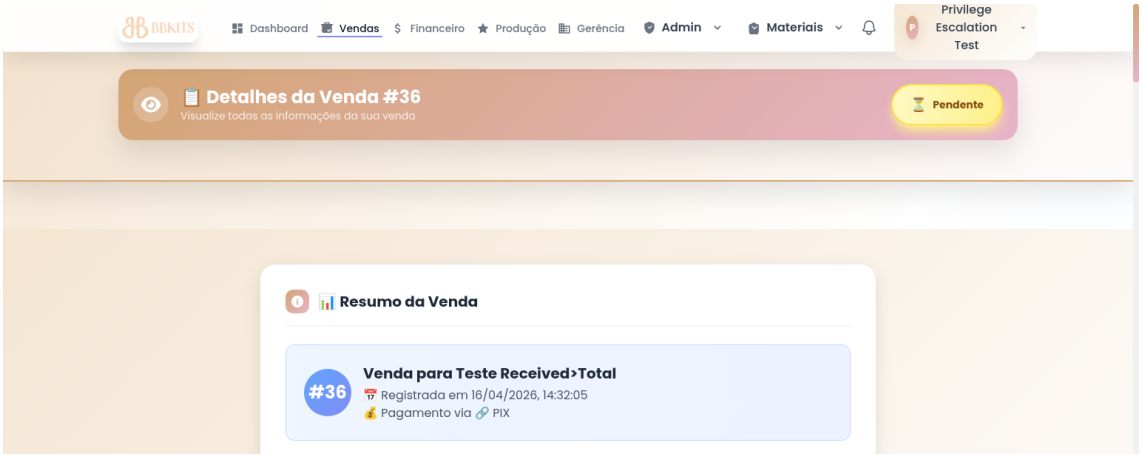
BUG-09 — Sem validação de valor máximo de pagamento ALTO

Descrição:
Pagamentos que excedem o total da venda são aceitos sem aviso.

Passos para Reproduzir:
1. Venda de R$100
2. Registrar pagamento de R$500
3. Aceito sem erro

Impacto:
Overpayments não controlados causam inconsistência financeira.

Evidência (screenshot):



BUG-10 — Telefone aceita qualquer formato MÉDIO

Descrição:
Campo client_phone aceita qualquer string sem validação de formato brasileiro.

Passos para Reproduzir:
1. Criar venda com phone="abc"
2. Aceito sem erro

Impacto:
Dados de contato inválidos impossibilitam contato com cliente.

BUG-11 — Falta paginação na listagem de vendas — BAIXO

Descrição:
A listagem carrega todas as vendas de uma vez sem paginação.

Passos para Reproduzir:
1. Acessar /sales com muitos registros
2. Observar carregamento

Impacto:
Performance degradada com volume crescente de dados.

BUG-12 — Data de entrega pode ser anterior à data de produção — MÉDIO

Descrição:
delivery_estimate pode ser definida antes de production_estimate.

Passos para Reproduzir:
1. Criar venda com delivery < production
2. Aceito sem erro

Impacto:
Datas logicamente impossíveis nos pedidos.

BUG-13 — Sem confirmação ao deletar venda — BAIXO

Descrição:
Vendas podem ser deletadas sem diálogo de confirmação.

Passos para Reproduzir:
1. Clicar em deletar venda
2. Venda removida imediatamente

Impacto:
Risco de exclusão acidental de vendas.

BUG-14 — remaining_amount zerado em vendas recusadas com saldo pendente — ALTO

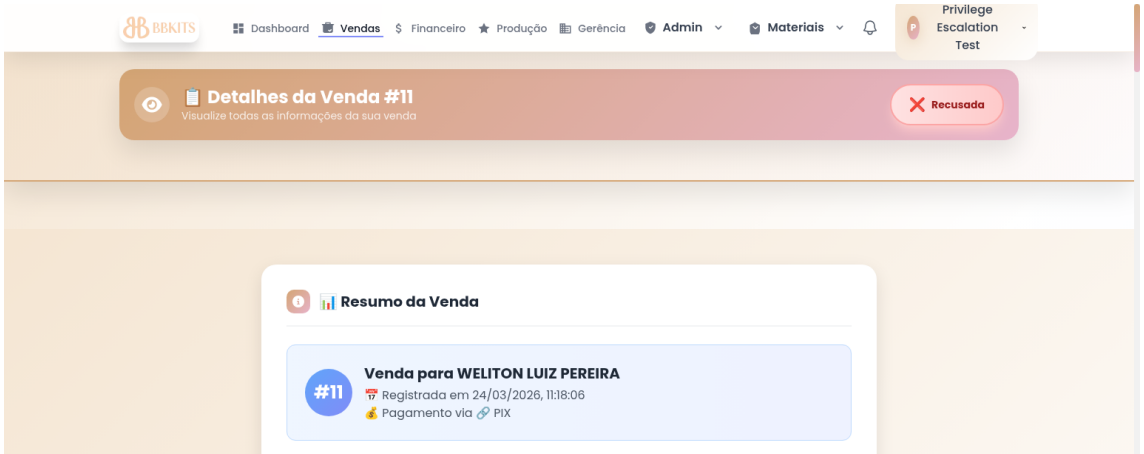
Descrição:
Vendas recusadas com pagamentos parciais mostram remaining_amount=0 ao invés do saldo real pendente. Ex: Venda #11 com R$430 pagos de R$508 mostra remaining=R$0.

Passos para Reproduzir:
1. Criar venda com pagamento parcial
2. Recusar a venda
3. Verificar remaining_amount via API

Impacto:

Impossível rastrear valores pendentes de reembolso em vendas recusadas.

Evidência (screenshot):



BUG-15 — Vendas recusadas mantêm pagamentos sem mecanismo de reembolso

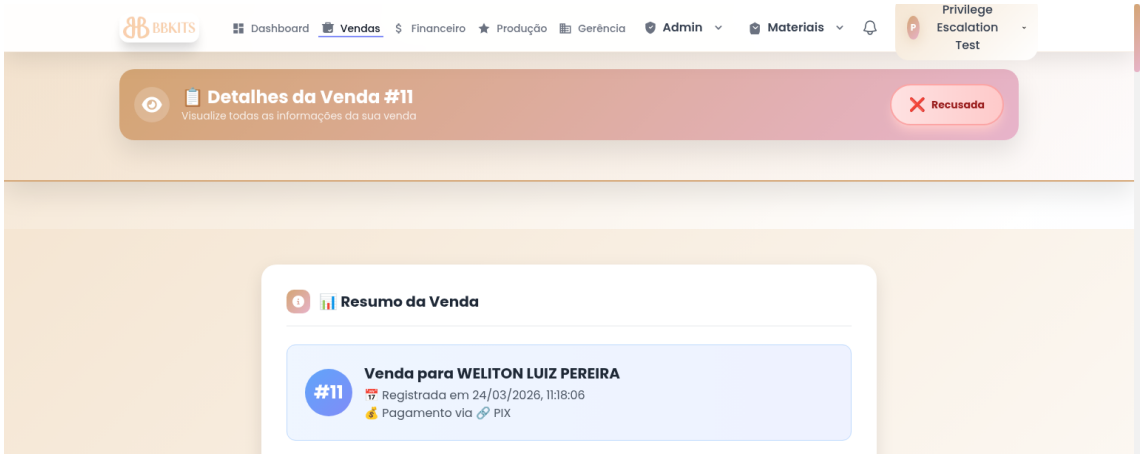
CRÍTICO

Descrição:
Vendas #11 (R$430) e #8 (R$330) foram recusadas mas mantêm pagamentos registrados. Não existe funcionalidade de reembolso no sistema.

Passos para Reproduzir:
1. Registrar pagamentos em uma venda
2. Recusar a venda
3. Verificar que pagamentos continuam registrados sem opção de estorno

Impacto:
Dinheiro do cliente retido sem processo de devolução. Risco legal e financeiro.

Evidência (screenshot):



BUG-16 — Cálculo de progresso inconsistente em overpayments

MÉDIO

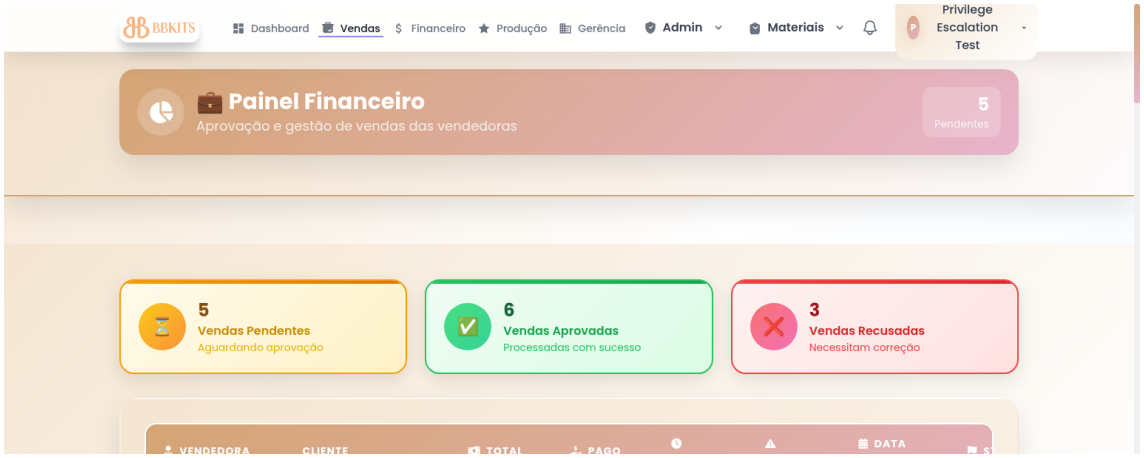
Descrição:

Venda #28 mostra 357% de progresso (R$3570 recebido de R$1000). O sistema não limita o progresso a 100% nem bloqueia overpayments.

Passos para Reproduzir:
1. Registrar pagamentos que excedam o total
2. Verificar campo progress

Impacto:
Interface confusa e dados financeiros incorretos.

Evidência (screenshot):



BUG-17 — Stored XSS: Payloads aceitos e armazenados sem sanitização server-side

ALTO

Descrição:
Campos client_name, child_name e notes aceitam payloads XSS como <script>alert("XSS")</script> e <img src=x onerror=alert(1)>. Vue.js escapa na renderização padrão, mas não há sanitização no servidor. Qualquer uso futuro de v-html ou innerHTML renderizaria o XSS.

Passos para Reproduzir:
1. POST /sales com client_name=<script>alert("XSS")</script>
2. Venda #33 criada com sucesso
3. Payload armazenado no banco de dados

Impacto:
Risco de XSS armazenado se qualquer template usar renderização HTML insegura. Dados maliciosos no banco.

Evidência (screenshot):

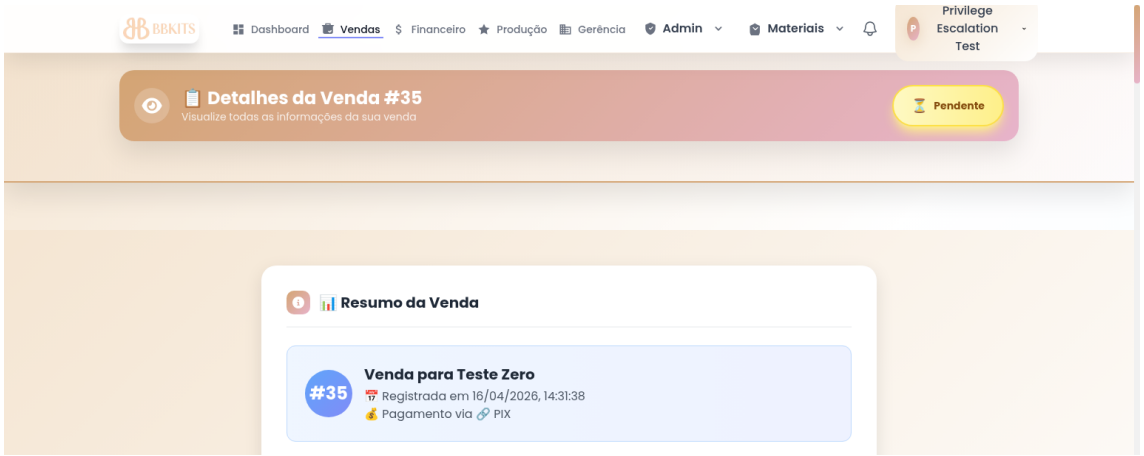
BUG-18 — Venda com valor R$0.00 aceita sem validação ALTO

Descrição:
POST /sales com total_amount=0 é aceito. Validação rejeita valores negativos (min:0) mas aceita zero.

Passos para Reproduzir:
1. POST /sales com total_amount=0
2. Venda criada com status 200

Impacto:
Vendas fantasma com valor zero poluem relatórios financeiros.

Evidência (screenshot):



BUG-19 — received_amount pode exceder total_amount na criação da venda CRÍTICO

Descrição:
Venda criada com total_amount=R$100 e received_amount=R$500 é aceita sem validação. Não existe regra received_amount <= total_amount.

Passos para Reproduzir:
1. POST /sales com total_amount=100, received_amount=500
2. Venda #36 criada com sucesso

Impacto:
Dados financeiros completamente inconsistentes. Saldo negativo implícito desde a criação.

Evidência (screenshot):

BUG-20 — CPF inválido aceito (00000000000) MÉDIO

Descrição:
CPF "00000000000" é aceito sem validação de dígitos verificadores. Sem validação de CPF real no servidor.

Passos para Reproduzir:
1. POST /sales com client_cpf=00000000000
2. Venda #37 criada com sucesso

Impacto:
Dados cadastrais inválidos. Problemas para emissão de notas fiscais.

Evidência (screenshot):

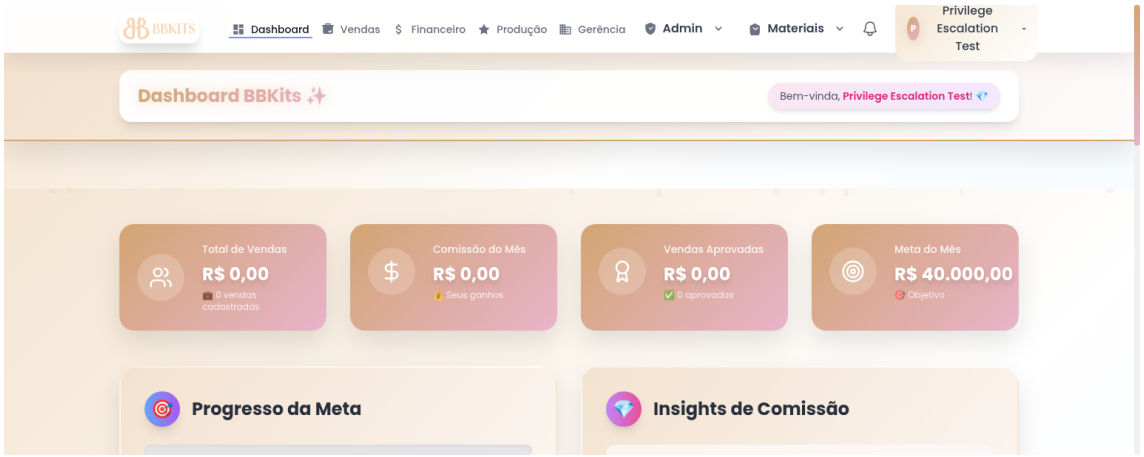
BUG-21 — Formulário de login sem method="POST" expõe credenciais na URL ALTO

Descrição:
O <form> de login não possui atributo method="POST" nem action. Se o JavaScript falhar, o form.submit() nativo envia via GET, expondo email e senha na URL: /login?email=...&password=...

Passos para Reproduzir:
1. Inspecionar HTML do form de login
2. Verificar ausência de method="POST"
3. Submeter form nativamente: credenciais na URL

Impacto:
Vazamento de credenciais em logs de servidor, histórico do navegador e headers Referer.

Evidência (screenshot):



BUG-22 — Sem rate limiting no login - vulnerável a brute force

ALTO

Descrição:
8 tentativas consecutivas de login falho não ativam nenhum rate limiting ou throttle. Todas retornam status 200.

Passos para Reproduzir:
1. Enviar 8 POSTs rápidos para /login com senhas erradas
2. Todas as respostas retornam 200
3. Nenhum bloqueio ou delay

Impacto:
Atacante pode realizar ataques de força bruta sem restrição.

Evidência (screenshot):

Recomendações

Recomendações

1. Validação Server-Side Urgente:
Implementar validação rigorosa: total_amount > 0, received_amount ≤ total_amount, CPF com dígitos verificadores, telefone no formato brasileiro, CEP válido.

2. Sanitização de Entrada (XSS):
Sanitizar todos os campos de texto no servidor antes de armazenar. Usar htmlspecialchars() ou biblioteca como HTMLPurifier. Nunca confiar apenas no framework frontend.

3. Rate Limiting no Login:
Implementar throttling (ex: 5 tentativas por minuto por IP/email). Laravel possui ThrottlesLogins nativo - verificar se está habilitado.

4. Form de Login com method=POST:
Adicionar method=POST e action=/login no formulário HTML para evitar fallback GET.

5. Fluxo de Reembolso:
Criar mecanismo de estorno/reembolso para vendas recusadas que possuem pagamentos.

6. Lógica de Vendas Recusadas:
Bloquear novos pagamentos em vendas recusadas. Manter remaining_amount correto para rastreio.

7. Correção de Registro:
Corrigir erro 500 no registro de vendedoras e financeiros. Verificar migration/seeder.

8. Limite de Progresso:
Limitar barra de progresso a 100%. Alertar sobre overpayments.